Prepared 2026-11-11 · operations

Development web source only. Module availability and hosted services require separate acceptance. Native and production deployment are separate.

`Source 040f03cf24b9c54e3ebbb74466cb2c57db0020d4`

`Application 25dcce3273fe0dd5059f43146e27711eaa0b7d8ed706ad1b8dbb249420753d40`

NEVORA web operations guide

This is a source-bound operator distribution for web onboarding, payroll workers, Web Push and their independent observer. It supplies preparation and review steps; actual activation status must be read from the selected authenticated environment. Native apps/push and production release authorization are separate. Use the guide index and accompanying manifest for source identity.

Establish custody before operating

Record the approved environment, exact source/deployment and artifact hashes, workspace/company, incarnation, operator, selected provider targets and private credential-store references. Verify actual runtime identity and denied capabilities; labels such as Preview or Production are insufficient to establish database isolation. Never rehearse against customer data or copy production credentials into a test environment.

Use approved stores and the selected runbook's restricted principals. Do not put credentials, connection strings, private enrollment profiles, invitation proofs, mail bodies or employee/pay data in source, commands, chat or receipts. Reports use opaque references and aggregate outcomes. Installed tooling, configuration, authentication, enabled processing and observed business success are separate states.

Work	Detailed source-owned procedure
Company admission, provisioning and restore	Self-service onboarding
Company-specific worker custody	Enrollment runbook
Managed host, observer, pause/drain	Managed workforce
Canonical one-shot workers and legacy supervision	Private workforce packet
Finite Web Push/SMTP acceptance	Notification acceptance
Incident coverage and renewals	Renewal/on-call handoff

Work	Detailed source-owned procedure
Privacy fulfillment and withdrawal	Deletion runbook

Dated runbooks retain historical evidence. Recheck their targets, receipts, backups and source against the approved candidate before applying a procedure. Do not treat a prepared packet as evidence that its hosted steps ran.

Admission and provisioning

Keep onboarding, provider creation, provisioner processing and invitation delivery closed until their separate gates pass. Displaying the signup host does not open registration. Production admission defaults closed; approved-recipient admission allows only the configured approved inbox. An open production admission mode combined with that inbox fence fails closed. Denied registration must not persist an account or dispatch mail.

Before any approved provisioning window, verify the selected account/region, resource policy, positive bounded daily allowance and explicit total-project cap. Capacity reservations and pending/unknown provider attempts continue to occupy their slots; do not clear them to make a backlog fit. A daily limit alone is not a total resource limit. Reconcile an ambiguous provider create against the exact original operation and immutable resource identity before proceeding. Never create another project or delete/recreate a company as compensation.

The production signup provisioner uses the explicit `production-signup-v1` profile with its fixed signup/portal destinations; other production worker or billing roles and workforce enrollment are excluded from that profile. Its tenant/trial commerce binding is part of company setup and does not charge a customer. Explicit resource-policy limits must match the provider's returned project/endpoint settings. See the source integration handoff before replacing any separately deployed signup artifact. Source integration does not deploy that artifact or open admission.

Owner grants and invitations have distinct lifetimes and recovery contracts. Provider acceptance is not inbox receipt. After a lost response, inspect the original operation rather than sending a new invitation or resetting a password. Existing company access remains independent of whether new signup is open.

Workers, enrollment and health

The canonical payroll/notification services own job deduplication, leases, authorization and retry policy. The host supervises bounded commands; exit zero means an invocation completed, not that payroll was approved, money moved or a notice reached a person. Monitor only the commands actually authorized/enabled.

For company-specific staging enrollment, use the reviewed recipient request, independently pinned binding and per-company restricted reader. The enrolled host holds the recipient private key and company reader, not shared provisioning roots or an Owner token. Do not reconstruct the older shared-root host profile from a historical packet. Admission expiry/revocation does not rotate an underlying database password already disclosed to a compromised recipient; that requires a separately reviewed credential rotation.

Start host and observer closed. Match compiled host/monitor sources, pinned destinations, exact company/environment/incarnation and enabled-command count. Verify restricted grants and actual private state ownership. `/ready` is process readiness only. Authenticated `/private/health` adds bounded queue/invocation evidence; a healthy response does not prove correct payroll or device delivery. An empty alert inbox is never proof of health.

Web Push encryption-key changes require the separate key-continuity procedure. Keep old decrypt capability across every app, worker and recovery reader until stored subscriptions, returning installation cookies and cleanup receipts are qualified. A zero old-ciphertext count does not establish client continuity. Do not retire keys early, downgrade to an older reader after new writes, rotate VAPID as a substitute, or resend an uncertain provider submission.

Before a hosted source/schema upgrade, follow the timestamp compatibility procedure. Some older invitations need verified Owner reissue, and pending timecards may need fresh review. Preserve finalized records, approved payroll and audit history.

Alerts, incidents and public uptime

The selected future failure-alert inbox is `support@thevelani.com`. Jose assigned himself as primary and Ilianis Soto as secondary with 24/7 coverage. The on-call handoff records the approved internal acknowledgement targets: 15 minutes for critical incidents and 1 hour for lower-severity incidents. These are ownership/triage targets, not resolution guarantees or a public SLA. Verify responder access, actual receipt and the response process before unattended use. A support response aim is not an incident SLA. Keep a current private renewal/expiry/cost register; no runbook approves a purchase, upgrade or new subscription.

For a finite authorized delivery exercise, bind the source, fictional scope, recipient/device, window, attempt ceiling and rollback owner. Record queued, provider-accepted, device-displayed or inbox-observed results separately. Keep automatic schedules/delivery closed outside that approved window. Unknown SMTP or push acceptance is not a safe retry signal.

When an incident occurs:

1. Check the independent observer's own last tick/source and the selected host's private health, receipts and canonical queue state.
2. Preserve a restricted incident record with times, opaque scope/reference, aggregate counts and accepted/unknown/definite-failure classification.
3. Pause the observer before planned worker drain. Stop new work in the exact affected scope, prove old processes stopped and preserve durable receipts.
4. Reconcile business/provider outcomes before recovery. Never reset attempts, leases, company identity or stale locks merely to make health green.
5. Resume only the approved matching source/scope after custody and cleanup are established. Observe fresh ticks and inspect remaining failed work. A code rollback cannot unsend a message or reverse a completed business mutation.

Private worker health is not public uptime coverage. Public monitoring acceptance still needs an approved public target, safe expected response, check interval and failure/recovery criteria, independent execution, actual alert destination and receipt, named responder/coverage, incident

recovery evidence and approved cost/privacy boundaries. No public platform, staffed uptime promise or new telemetry is activated by this bundle.

Privacy cases, retention and restore

Use current approved facts in `src/lib/legal/policies.ts` and the request's recorded policy version. Privacy fulfillment remains manual; a received request is not erasure. Inventory access, profile, work records, communications, payroll, photos, advisor records, providers and backups. Record removal/restriction, retained basis/end date or an owned hold, unresolved dependencies and provider outcomes before declaring completion. Preserve immutable evidence and other workers' records. Do not use blanket SQL deletion or disable security/audit controls.

The case-readiness reviewer checks opaque evidence shape, exact binding and consistency for completion, withdrawal and restore. `review_ready` classifies recorded operator attestations only. It authenticates no person or provider fact and grants no mutation, withdrawal, activation or release authority. A blocked result requires resolving its evidence gaps, not changing the expected binding to match an unrelated case.

Withdrawal is Support-only while the request is received, before processing. The approved procedure requires trustworthy pre-request mailbox evidence, matching Employee ID and a recorded fresh single-use verification expiring after 15 minutes. A request reference, matching From address or newly supplied email is insufficient. The reviewer is not a challenge mailer. Missing historical evidence or unknown state keeps the action blocked.

Keep a restored company suspended. Verify exact backup/company/incarnation, retire restored credentials through the original operation, reconcile the current erasure register and completed cases, and reapply required restrictions before separately reviewed reactivation. A successful restore rehearsal does not prove actual hosted recovery history or authorize reopening a company.

D04 communications retention remains held. The current command boundary requires actual loopback PostgreSQL and disposable ownership evidence. Do not invent a retention duration, edit the guard or use a generic flag to activate live communications. Obtain the explicit approved policy and erasure mechanism through the existing decision process. Backup configuration and the observer's journal retention need their own current evidence; no automatic purge follows from these guides.

Handoff and release gate

Record changes, exact source/artifacts, checks actually run, provider/hosted steps actually observed, failed or unknown outcomes, open independent findings, owner and next gate. Source, local tests, exact-candidate CI, development integration and actual hosted acceptance are distinct evidence. Main, production, real messages, customer mutations and paid changes need their applicable explicit authorization; documentation cannot supply it.